

# Incident Report: Security Investigation & Threat Intelligence

**Date:** July 15, 2026  
**Subject:** Analysis of Simulated Spear-Phishing Campaign (Incident ID: SP-2026-07-15)  
**Classification:** Internal / Restricted

## 1. Executive Summary

This report details the investigation into a simulated spear-phishing campaign directed against the organization on July 14, 2026. The objective of this campaign was to lure employees into executing a malicious payload disguised as an urgent vendor invoice, leading to potential command-and-control (C2) communication.

The attack utilized social engineering tactics, specifically invoice fraud, combined with a weaponized document to achieve initial access. The incident was successfully contained; however, the investigation identified gaps in existing email filtering and endpoint detection capabilities.

## 2. Technical Analysis & Investigation

The investigation lifecycle involved isolating the delivery mechanism, analyzing the malicious artifact, and correlating telemetry data across industry-standard threat intelligence platforms.

### Attack Vector Description

| Source           | Findings                                                                                                |
|------------------|---------------------------------------------------------------------------------------------------------|
| VirusTotal       | 42/75 engines flagged the file as Trojan.PowerShell.Agent. High entropy detected in VBA macros.         |
| AbuseIPDB        | The C2 IP address (45.33.22.11) has been reported for malicious activity 14 times in the last 72 hours. |
| OTX (AlienVault) | Domain secure-invoices-portal[.]com associated with a known campaign targeting the financial sector.    |

The threat actor sent an email appearing to originate from billing@partner-services-corp[.]com. The email contained a Microsoft Excel attachment named Invoice\_INV-99283\_July.xlsm. Upon opening, the document prompted the user to "Enable Content," which executed an obfuscated PowerShell script to initiate a network connection.

### Intelligence Correlation

Data from the malicious payload and network traffic was analyzed via threat intelligence sources:

### 3. Threat Mapping (MITRE ATT&CK)

The observed behaviors were mapped against the MITRE ATT&CK framework to assess the tactical progression of the adversary.

| ATT&CK Technique           | ID    | Description                                                                     |
|----------------------------|-------|---------------------------------------------------------------------------------|
| Phishing                   | T1566 | Used spear-phishing attachment to gain initial access via social engineering.   |
| Command & Scripting        | T1059 | Used PowerShell to execute obfuscated commands from the malicious macro.        |
| Application Layer Protocol | T1071 | C2 traffic disguised as standard HTTP/S web traffic to bypass egress filtering. |

### 4. Indicators of Compromise (IOCs)

The following artifacts were identified and confirmed during the investigation. These have been added to the enterprise blocklist.

- **Malicious Domain:** secure-invoices-portal[.]com
- **C2 IP Address:** 45.33.22.11
- **File Hash (MD5):** d41d8cd98f00b204e9800998ecf8427e
- **File Hash (SHA-256):**  
e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855

## 5. Recommended Security Controls & Mitigation

To strengthen the organization's posture against similar threats, the following improvements are recommended:

### Tactical (Immediate)

1. **Email Gateway Configuration:** Implement stricter heuristic filtering on incoming attachments. Specifically, block .xlsm (Macro-Enabled Excel) files from external senders by default.
2. **Network Egress Filtering:** Restrict internal hosts from communicating directly with unknown public IPs on port 443. Enforce usage of the corporate proxy/gateway.

### Strategic (Long-Term)

- **Endpoint Detection & Response (EDR):** Configure EDR policies to alert on child processes spawned by Microsoft Office applications (e.g., excel.exe -> powershell.exe).
- **Security Awareness:** Initiate a phishing simulation training program focused on identifying "Invoice/Payment" lure templates.
- **PowerShell Constrained Language Mode:** Deploy system-wide policy to enforce PowerShell Constrained Language Mode (CLM) to limit the capability of malicious scripts.

## 6. Conclusion

The simulated spear-phishing campaign was highly effective due to the sophistication of the social engineering lure. While the incident was contained, the reliance on user vigilance is insufficient. By implementing the recommended technical controls, the organization will shift from a reactive posture to a proactive defense model, significantly reducing the success rate of future phishing attempts.